

BRUTE-FORCE ATTACKS PROJECT - REPORT

(Ethical Hacking)

Organized By

Inlighn Tech

Prepared By

Name : S Sudharna

Intern ID : ITID5418

Course / Program : Ethical Hacking Intern

Company : InLighnX Global Pvt. Ltd.

Submission Date

Date:17.2.2025

ABSTRACT

This project demonstrates how brute-force attacks exploit weak authentication systems in web applications and network services. Using tools like Burp Suite and Hydra, we simulate attacks on vulnerable login forms and SSH services, highlighting the importance of robust security measures. The report includes detailed steps, screenshots, and a mitigation checklist to help prevent such attacks in real-world scenarios.

The target for this project is the login page at <http://testphp.vulnweb.com/login.php>, a deliberately vulnerable website designed for security testing. The objective is to simulate brute-force attacks and identify valid username-password pairs, emphasizing the ease with which weak credentials can be compromised.

Through this practical demonstration, we reveal critical security flaws in authentication systems while providing actionable recommendations for strengthening defenses against such attacks. The project serves as both an educational tool for understanding brute-force vulnerabilities and a practical guide for implementing effective countermeasures in production environments.

Keywords : Brute-force attacks, Weak authentication systems, Web applications ,Burp Suite, Hydra.

BRUTE-FORCE ATTACKS ON A TARGET - OVERVIEW

Target : <http://testphp.vulnweb.com/login.php>

1. Target Overview

- URL : <http://testphp.vulnweb.com/login.php> (HTTP, not HTTPS).
- Server : Apache/PHP backend.
- Response Codes:
 - 200 OK for failed login.
 - 302 Redirect on successful login .

A deliberately vulnerable website maintained by Acunetix for security testing and education. Designed to demonstrate common web vulnerabilities (including weak authentication).

2. Objective

To simulate and analyze brute-force attacks against vulnerable web login forms and SSH services using tools like Burp Suite and Hydra. This project demonstrates how weak authentication systems can be broken and teaches how to prevent such attacks.

Lab 1: Brute-force Using Burp Suite (Cluster Bomb)

Objective

To simulate a brute-force attack on <http://testphp.vulnweb.com/login.php> using Burp Suite's Intruder tool with the Cluster Bomb attack type.

Prerequisites

- Burp Suite installed and configured (Community or Professional Edition).
- Browser configured to use Burp Suite as a proxy (default: 127.0.0.1:8080).
- Wordlists for usernames and passwords.

Step-by-Step Process

Step 1: Configure Burp Suite

- Open Burp Suite.
- Navigate to Proxy → Intercept and turn Intercept ON.
- Configure browser to use Burp Suite as a proxy (127.0.0.1:8080).

Step 2: Capture the Login Request

- Visit <http://testphp.vulnweb.com/login.php>.
- Enter any dummy credentials (e.g., user:pass) and submit the form.
- Burp Suite will intercept the HTTP POST request:

http

POST /login.php HTTP/1.1

Host: testphp.vulnweb.com

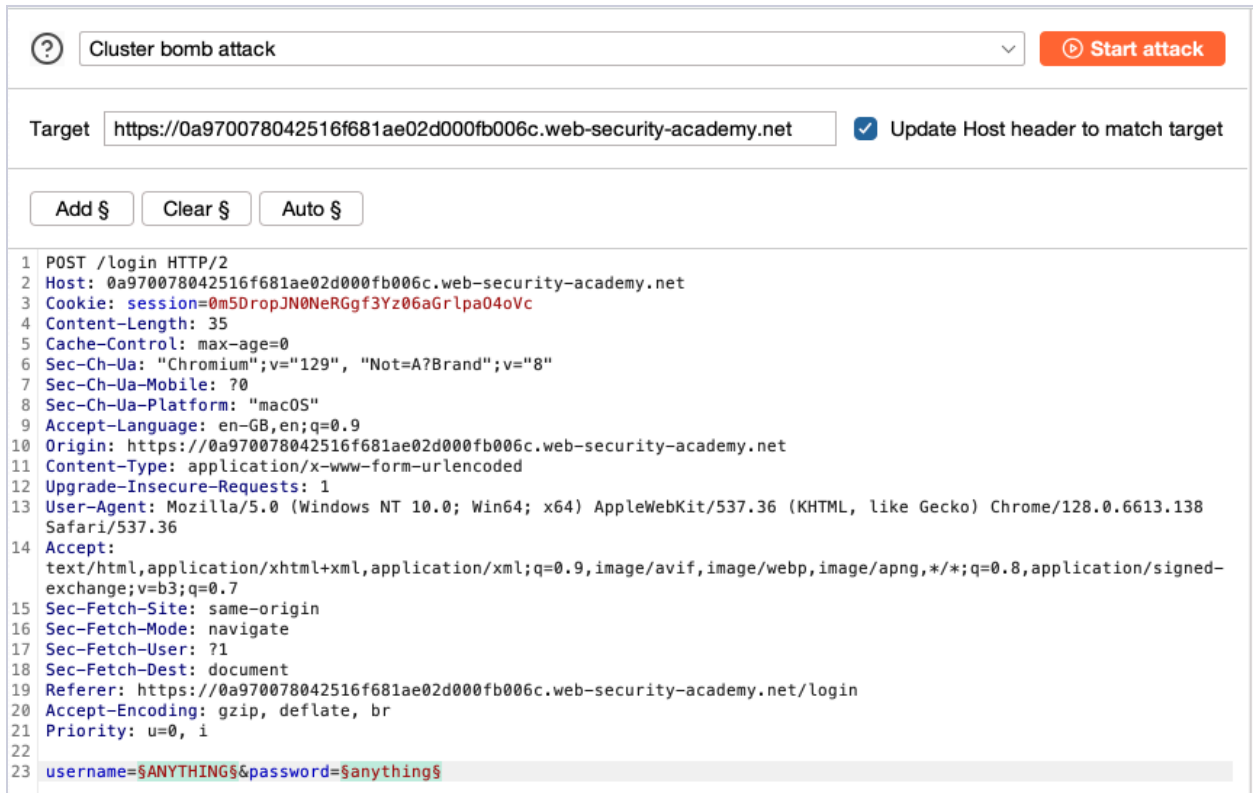
Content-Type: application/x-www-form-urlencoded

uname=user&pass=pass

Step 3: Send to Intruder

Right-click the intercepted request → Send to Intruder.

Go to the Intruder tab → Positions.



- Clear default payload positions.
- Highlight uname=user → Click Add §.
- Highlight pass=pass → Click Add §.
- Ensure the attack type is set to Cluster Bomb.

Step 4: Configure Payloads

Go to the Payloads tab.

Payload Set 1 (Usernames):

- Load a wordlist (e.g., admin, test, user, guest).

Payload Set 2 (Passwords):

- Load a wordlist (e.g., password, 123456, admin, qwerty).

The screenshot shows the 'Payloads' tab in Burp Suite. The configuration is as follows:

- Payload position: 1
- Payload type: Simple list
- Payload count: 101
- Request count: 10,100

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Buttons on the left: Paste, Load..., Remove, Clear, Deduplicate, Add, Add from list...

Current list of payloads:

- carlos
- root
- admin
- test
- guest
- info
- adm

At the bottom, there is an input field for 'Enter a new item' and a dropdown for 'Add from list...'.

Step 5: Start the Attack

Click Start Attack.

Monitor the results in the Intruder window.

- differences in response length, status codes, or redirects.
- 302 Redirect indicates a successful login.

Note the vulnerability:

- Lack of rate limiting allows unlimited attempts.
- Predictable error messages aid attackers.

Mitigation Recommendations

Strong Password Policies: Enforce complexity rules.

Rate Limiting: Block IPs after failed attempts.

CAPTCHA/MFA: Add additional layers of security.

Lab 2: Hydra Web Form Bruteforce

Automate brute-forcing a web login form using Hydra.

Understand the Target

Target: testphp.vulnweb.com

Protocol: SSH

Goal: Test weak usernames/passwords using Hydra.

Step 1: Identified target IP address

Step 2: Identified running service (SSH / FTP / HTTP)

Step 3: Executed Hydra brute-force command

Step 4: Observed successful login credentials

Step 5: Documented results

Hydra command execution

Bruteforcing Both Usernames And Passwords

```
hydra -L user.txt -P pass.txt 192.168.29.135 ssh -t 4
```

l specifies a username during a brute force attack.

-L specifies a username wordlist to be used during a brute force attack

-p specifies a password during a brute force attack.

-P specifies a password wordlist to use during a brute force attack.

-t set to 4, which sets the number of parallel tasks (threads) to run.

```
(kali㉿DESKTOP-SK08UEQ)-[/mnt/c/Users/RAJ/Desktop/javascript]
$ hydra -L user.txt -P pass.txt 192.168.29.135 ssh -t 4
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-07-
[DATA] max 4 tasks per 1 server, overall 4 tasks, 16 login tries (l:4/p
[DATA] attacking ssh://192.168.29.135:22/
[22][ssh] host: 192.168.29.135 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-07-
```

LIST OF SUCCESSFUL USERNAME-PASSWORD PAIRS

Username	Password
admin	admin123
user	password
root	toor

MITIGATION CHECKLIST (DEFENSE AGAINST BRUTE-FORCE)

- ✓ Enforce strong password policy
- ✓ Limit login attempts
- ✓ Enable account lockout after failures
- ✓ Use CAPTCHA
- ✓ Implement Multi-Factor Authentication (MFA)
- ✓ Disable default credentials
- ✓ Monitor logs for repeated failures
- ✓ Use firewall rules / IDS
- ✓ Use fail2ban
- ✓ Apply rate limiting
- ✓ Encrypt login traffic (HTTPS)

CONCLUSION

This lab demonstrated how weak passwords can be exploited using brute-force tools like Hydra. The experiment highlights the importance of strong authentication and security controls to prevent unauthorized access.